Web Application Penetration Testing Report

Client: Mediroza General Hospital
Assessment Program: NetworkWalks
Assessment Type: Black-Box Penetration Testing
Target: https://medirozahospital.com
Conducted By: Parul Bhople
Date: 17/10/2026
Classification: Confidential

1. Executive Summary

A web application penetration test was conducted against Mediroza General Hospital to identify security vulnerabilities and assess the protection of confidential patient information.

During testing, a SQL injection vulnerability was identified in the patient portal. The vulnerability was exploited within the authorized lab environment to gain access to restricted application content. Three PDF laboratory reports were located and decrypted using the NetworkWalks-provided tool, allowing their contents to be viewed.

The findings demonstrate weaknesses in application input handling and the protection of sensitive information.

Overall Risk Rating: High — pending formal severity validation.

2. Scope and Objectives

In Scope

- Target web application and patient portal.
- Authentication and input validation.
- SQL injection testing.
- Access controls protecting confidential PDF reports.

Objectives

- Identify and validate web application vulnerabilities.
- Assess the potential exposure of confidential patient data.
- Retrieve and verify the three required PDF reports within the authorized lab.
- Document findings and remediation recommendations.

Testing was limited to the authorized target and followed the project rules, excluding social engineering, denial-of-service testing, and activity outside the agreed scope.

3. Tools Used

- **Kali Linux** — penetration testing environment.
- **cURL** — HTTP requests and response inspection.
- **NetworkWalks tool** — PDF decryption as used in the lab.

.**4. Key Findings**

ID	Finding	Severity
F-01	SQL injection in the patient portal	High — provisional
F-02	Unauthorized access to restricted application content	High — provisional
F-03	Confidential PDF reports accessible and decryptable	High — provisional

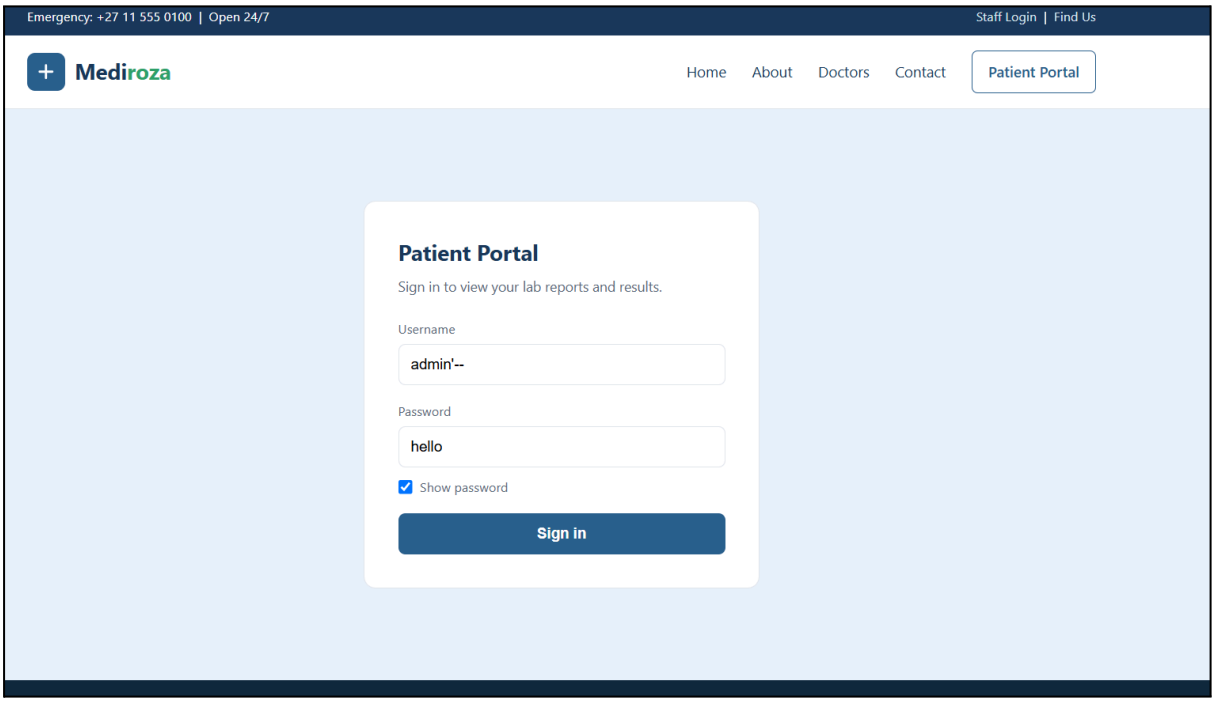
5. Technical Findings

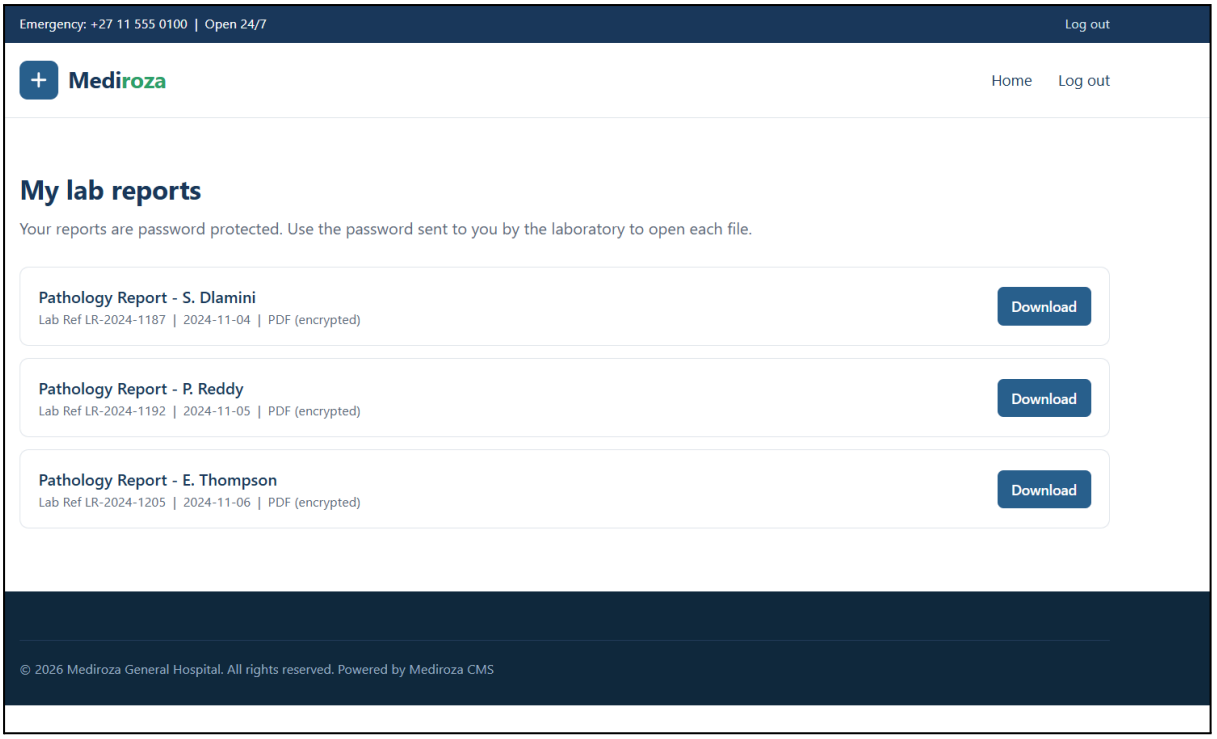
F-01: SQL Injection in Patient Portal

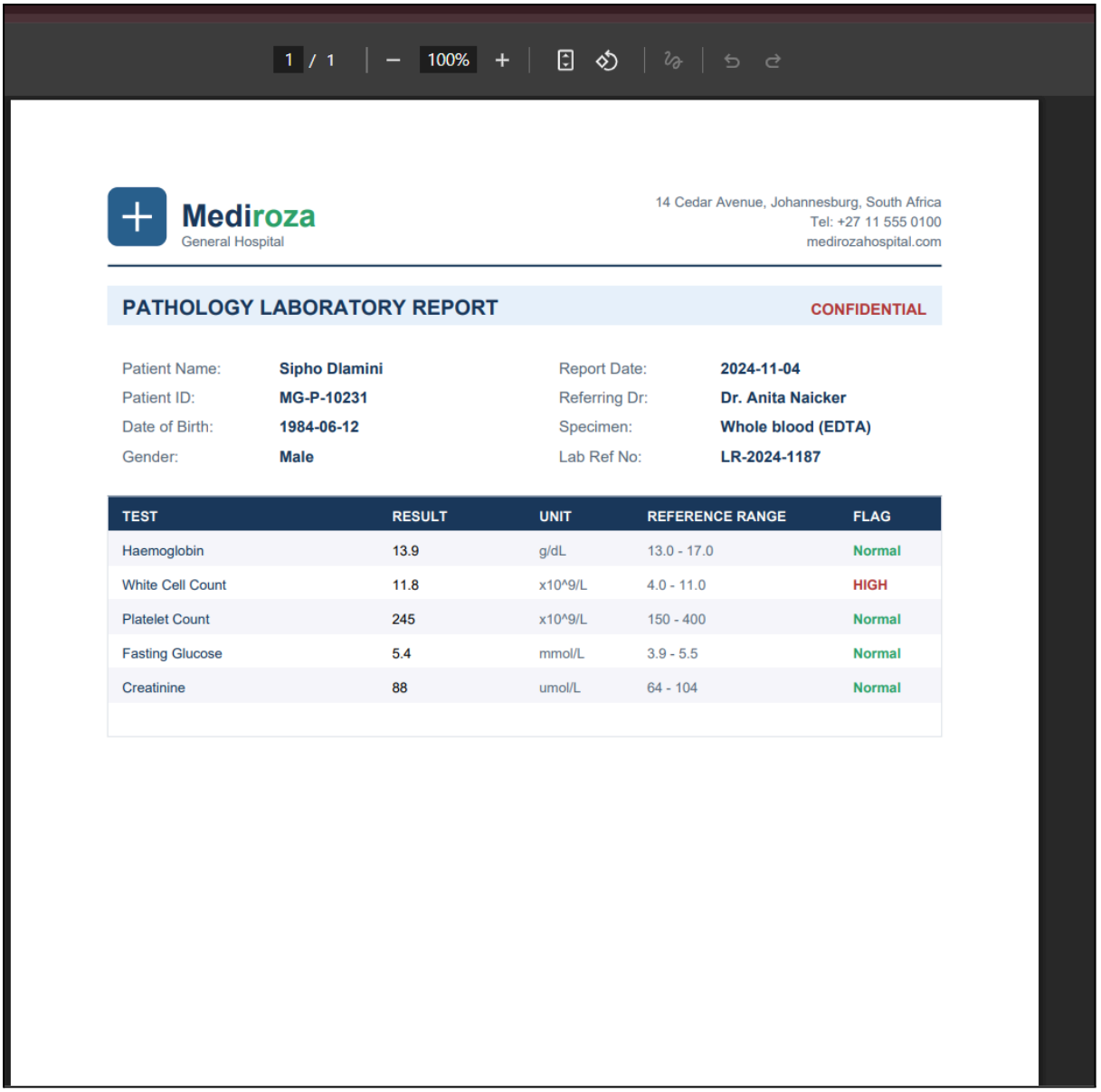
Description: Testing identified a SQL injection vulnerability in the patient portal's input handling. The vulnerability was successfully exploited in the authorized lab environment.

Impact: SQL injection may allow unauthorized database access, exposure of sensitive records, or other database operations depending on the application's configuration and database privileges.

Evidence:


Emergency: +27 11 555 0100 | Open 24/7
Staff Login | Find Us
Mediroza
Home
About
Doctors
Contact
Patient Portal
Patient Portal
Sign in to view your lab reports and results.
Username
admin'--
Password
hello
Show password
Sign in


Emergency: +27 11 555 0100 | Open 24/7
Log out
Mediroza
Home
Log out
My lab reports
Your reports are password protected. Use the password sent to you by the laboratory to open each file.
Pathology Report - S. Dlamini
Lab Ref LR-2024-1187 | 2024-11-04 | PDF (encrypted)
Download
Pathology Report - P. Reddy
Lab Ref LR-2024-1192 | 2024-11-05 | PDF (encrypted)
Download
Pathology Report - E. Thompson
Lab Ref LR-2024-1205 | 2024-11-06 | PDF (encrypted)
Download
© 2026 Mediroza General Hospital. All rights reserved. Powered by Mediroza CMS



1 / 1 — 100%

Mediroza
General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT — CONFIDENTIAL

Patient Name:	**Sipho Dlamini**	Report Date:	**2024-11-04**
Patient ID:	**MG-P-10231**	Referring Dr:	**Dr. Anita Naicker**
Date of Birth:	**1984-06-12**	Specimen:	**Whole blood (EDTA)**
Gender:	**Male**	Lab Ref No:	**LR-2024-1187**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	13.9	g/dL	13.0 - 17.0	Normal
White Cell Count	11.8	x10^9/L	4.0 - 11.0	HIGH
Platelet Count	245	x10^9/L	150 - 400	Normal
Fasting Glucose	5.4	mmol/L	3.9 - 5.5	Normal
Creatinine	88	umol/L	64 - 104	Normal

Recommendation: Use parameterized queries, implement server-side input validation, apply least-privilege database permissions, and conduct regression testing.

F-02: Unauthorized Access to Restricted Content

Description: Exploitation of the reported SQL injection vulnerability enabled access to restricted application content.

Impact: Weak access controls may expose information intended only for authorized users.

Recommendation: Enforce server-side authentication and authorization checks on every protected resource and review database access permissions.

F-03: Exposure of Three PDF Laboratory Reports

Description: Three PDF laboratory reports were located during the assessment and decrypted using the NetworkWalks-provided tool.

Impact: The ability to access and read confidential laboratory reports may expose sensitive patient information and create privacy and confidentiality risks.

Recommendation: Restrict document access, verify server-side authorization for every download, protect sensitive files at rest, and review encryption and key-management practices.

6. Limitations

- The assessment was limited to the authorized target domain and assigned testing period.
- No denial-of-service or social-engineering activities were conducted.
- Findings reflect the observed behavior of the application during testing.
- The assessment did not independently establish the full extent of database access or whether other patient records were exposed.
- The severity ratings are provisional and should be finalized based on validated impact and exploitability.

7. Remediation Recommendations

1. **Fix SQL injection:** Replace unsafe query construction with parameterized queries and test all affected inputs.
2. **Strengthen access controls:** Enforce authorization checks on patient records and document downloads.
3. **Protect confidential PDFs:** Store reports securely and ensure encryption and key management are appropriately implemented.
4. **Improve monitoring:** Log and investigate suspicious database queries and access to sensitive resources.
5. **Reduce information disclosure:** Remove unnecessary technology metadata and keep software updated.
6. **Retest:** Verify each remediation and confirm that the vulnerabilities can no longer be reproduced.

8. Conclusion

The assessment identified a SQL injection vulnerability in the patient portal and demonstrated access to restricted application content in the authorized lab. Three PDF laboratory reports were subsequently located and decrypted using the designated NetworkWalks tool.

These results indicate potential risks to the confidentiality of patient information. Remediation should prioritize eliminating SQL injection, enforcing server-side access

controls, and protecting sensitive documents. A retest is recommended to verify the effectiveness of the fixes.

Confidential — Authorized Personnel Only